

cover-page.md

Підготував: Dr. Oleksandr Melnychenko, CEO at [Horizon Dynamics](#)

Salesforce vs. Custom Platform

Client Release Package

For Medical Agency Operations

Пакет документів

Цей пакет підготовлено для оцінки двох підходів до побудови операційної системи медичної агенції:

1. `Salesforce as core platform` (Salesforce як основна платформа)
2. `Custom platform as core platform` (власна платформа як основна платформа)

Пакет охоплює:

- стратегічне порівняння;
 - правовий і договірний ризик;
 - базовий фінансовий контур;
 - практичні умови для безпечної моделі впровадження.
-

Статус документа

- Версія: `Release Draft`
 - Формат: `Client-facing PDF package`
 - Дата підготовки: `Квітень 2026`
-

Важливе застереження

Матеріали в пакеті:

- не є індивідуальною юридичною консультацією;
 - не є комерційною офертою;
 - не замінюють фінальний договір, фінальний кошторис та окрему юридичну перевірку.
-

Склад пакета

1. `release-package-index.md`
2. `salesforce-vs-custom-platform.md`
3. `tco-financial-appendix.md`
4. `legal-risk-appendix.md`
5. `custom-platform-contract-checklist.md`

release-package-index.md

Підготував: Dr. Oleksandr Melnychenko, CEO at [Horizon Dynamics](#)

Release Package Index

Індекс релізного пакета документів для передачі клієнту у форматі PDF.

Статус документа

- Версія: Release Draft
- Формат: Client-facing PDF package
- Дата підготовки: Квітень 2026

1. Призначення пакета

Цей пакет підготовлено для презентації клієнту варіантів побудови операційної системи медичної агенції:

- на базі Salesforce;
- на базі власної платформи;
- з урахуванням правових, фінансових і договірних ризиків.

Матеріали орієнтовані на:

- CEO / власника бізнесу;
- операційного директора;
- фінансового директора;
- зовнішнього юриста;
- IT / security stakeholders (технічних і безпекових учасників прийняття рішення).

2. Склад пакета

Документ 1. Основне порівняння

docs/comparison/salesforce-vs-custom-platform.md

Містить:

- стратегічне порівняння Salesforce та власної платформи;
- product fit (відповідність продукту);
- data residency (локалізацію даних);

- encryption and audit (шифрування та аудит);
- access control (контроль доступу);
- medical workflow fit (відповідність медичному процесу);
- billing fit (відповідність фінансовому контуру);
- відповідальність при витоку;
- варіанти рішення;
- базову рекомендацію.

Документ 2. Legal Risk Appendix

`docs/comparison/legal-risk-appendix.md`

Містить:

- `controller / processor / sub-processor` logic;
- відповідальність при `personal data breach`;
- практичне пояснення "кого судять";
- відмінність між Salesforce scenario та custom platform scenario;
- юридичні питання, які обов'язково потрібно перевірити окремо.

Документ 3. Contract Checklist

`docs/comparison/custom-platform-contract-checklist.md`

Містить:

- checklist для договору по власній платформі;
- ownership and control (власність і контроль);
- security obligations (обов'язки щодо безпеки);
- incident response (реагування на інциденти);
- audit rights (права аудиту);
- liability / indemnities / insurance;
- exit and transition terms (умови виходу і передачі).

Документ 4. TCO and Entry Cost Appendix

`docs/comparison/tco-financial-appendix.md`

Містить:

- published pricing (опубліковані ціни) Salesforce;
 - entry cost scenarios (сценарії вартості входу);
 - recurring license baseline (базовий регулярний ліцензійний контур);
 - пояснення, що входить і не входить у фінансову модель;
 - список даних, які потрібно ще підтвердити для фінального TCO.
-

3. Рекомендований порядок читання

Для керівництва:

1. `salesforce-vs-custom-platform.md`
2. `tco-financial-appendix.md`
3. `legal-risk-appendix.md`

Для юриста:

1. `legal-risk-appendix.md`
2. `custom-platform-contract-checklist.md`
3. `salesforce-vs-custom-platform.md`

Для фінансового блоку:

1. `tco-financial-appendix.md`
2. `salesforce-vs-custom-platform.md`

Для технічної сторони:

1. `salesforce-vs-custom-platform.md`
 2. `custom-platform-contract-checklist.md`
-

4. Рекомендована структура PDF-комплекту

Для фінального PDF-пакета доцільно використати таку послідовність:

1. Cover page (титульна сторінка)
`docs/comparison/cover-page.md`
 2. Release Package Index (цей документ)
`docs/comparison/release-package-index.md`
 3. Salesforce vs. Власна платформа
`docs/comparison/salesforce-vs-custom-platform.md`
 4. TCO and Entry Cost Appendix
`docs/comparison/tco-financial-appendix.md`
 5. Legal Risk Appendix
`docs/comparison/legal-risk-appendix.md`
 6. Custom Platform Contract Checklist
`docs/comparison/custom-platform-contract-checklist.md`
-

5. Важливе застереження

Цей пакет є decision support package (пакетом для підтримки управлінського рішення).

Він:

- не є остаточним договором;
 - не є індивідуальною юридичною консультацією;
 - не є комерційною офертою;
 - не замінює окрему юридичну перевірку, фінальний кошторис і договірне узгодження.
-

6. Статус пакета

- Версія: Release Draft
 - Дата оновлення: Квітень 2026
 - Формат: Client-facing PDF package
-

Оновлено: Квітень 2026

salesforce-vs-custom-platform.md

Підготував: Dr. Oleksandr Melnychenko, CEO at [Horizon Dynamics](#)

Salesforce vs. Власна платформа

Клієнтське порівняння для медичної агенції. Версія підготовлена для подальшого оформлення в PDF. Інформація перевірена за публічними джерелами станом на квітень 2026 року.

Статус документа

- Версія: Release Draft
- Формат: Client-facing main document
- Дата підготовки: Квітень 2026

1. Executive summary (короткий висновок)

Salesforce - це сильна platform CRM (CRM-платформа), яка добре підходить для:

- lead management (керування лідами);
- sales pipeline (воронки продажів);
- customer service (сервісних процесів);
- швидкого запуску стандартних бізнес-процесів.

Водночас цільова система, відповідно до вже підготовленої архітектури та вимог, є не просто CRM, а patient operations platform (операційною платформою для роботи з пацієнтами), яка поєднує:

- medical intake (первинний медичний збір даних);
- anamnesis management (керування анамнезом);
- context-based access control (контекстне керування доступом);
- document governance (контроль життєвого циклу документів);
- appointment orchestration (координування медичних і немедичних термінів);
- interpreter workflow (процес роботи перекладачів);
- German billing contour (білінг за німецькими правилами);
- patient portal (портал пацієнта).

Тому стратегічне питання звучить не так:

"Чи хороший Salesforce?"

А так:

"Чи підходить Salesforce як ядро для операційної системи медичної агенції, що працює з чутливими даними пацієнтів?"

Для такого сценарію власна платформа є більш придатною базовою архітектурною основою. Водночас Salesforce може залишатися корисним у ролі окремого lead / sales CRM (CRM для маркетингу та лідів), якщо компанія розглядатиме гібридну модель.

2. Що саме порівнюється

У цьому документі порівнюються два підходи:

Підхід А. Salesforce як основна платформа

Тобто CRM, доступи, документи, медичний контур, процеси, частина або весь білінг будуються навколо екосистеми Salesforce.

Підхід В. Власна платформа як основна платформа

Тобто core system (ядро системи) будується спеціально під процеси агенції, а хмара, encryption model (модель шифрування), storage model (модель зберігання), access model (модель доступу) та business workflows (бізнес-процеси) контролюються замовником.

3. Що Salesforce об'єктивно вміє сьогодні

Щоб порівняння було чесним, важливо спочатку зафіксувати: Salesforce має не лише базовий CRM, а й розвинені продукти для security (безпеки), healthcare (медичних сценаріїв) та regulatory compliance (регуляторної відповідності).

3.1 Hyperforce EU Operating Zone (операційна зона ЄС)

За офіційною інформацією Salesforce:

- Hyperforce EU Operating Zone дозволяє для підтримуваних продуктів обробляти і зберігати customer data (дані клієнтів) всередині кордону ЄС;
- Salesforce окремо заявляє in-region support (підтримку персоналом у регіоні ЄС) для цієї моделі;
- водночас це стосується не всіх можливих сервісів без винятку, а select set of products (обмеженого переліку підтримуваних продуктів).

Висновок:

Salesforce сьогодні некоректно описувати як платформу, яка автоматично виводить усі дані до США. Водночас так само некоректно вважати, що питання data governance (керування даними) і transfer risk (ризик міжнародної передачі даних) у цій моделі зникають самі по собі.

3.2 Salesforce Shield (комплекс безпеки Salesforce)

За офіційними матеріалами Salesforce Shield включає:

- Platform Encryption (шифрування даних на платформі);
- Field Audit Trail (довгостроковий аудит змін полів);
- Event Monitoring (моніторинг подій і доступів);
- Data Detect (виявлення чутливих даних).

Salesforce прямо заявляє:

- AES 256-bit encryption (шифрування AES-256);
- BYOK, Bring Your Own Key (можливість використання власних ключів замовника);
- retention up to 10 years (зберігання історії аудиту до 10 років) для Field Audit Trail;
- event logging (журналювання подій) для великої кількості типів активності.

Висновок:

Salesforce має сильні security controls (контролі безпеки). Питання полягає не в базовій безпеці платформи, а в тому, чи достатньо цих можливостей саме для спеціалізованого доменного сценарію агенції.

3.3 Health Cloud (галузевий продукт для медицини та healthcare)

За публічними матеріалами Salesforce Health Cloud підтримує:

- unified health record (об'єднаний медичний запис);
- healthcare data models (галузеві моделі даних);
- care management (керування доглядом / супроводом);
- healthcare interoperability (медичну інтероперабельність), зокрема FHIR integration (інтеграції через FHIR).

Висновок:

Некоректно стверджувати, що Salesforce взагалі не має медичних можливостей. Такі можливості існують. Однак це не означає, що платформа природно покриває саме операційну модель медичної агенції цього типу.

3.4 Data Privacy Framework (механізм правової передачі даних)

Публічно доступна інформація Salesforce також показує, що компанія має Data Privacy Framework registration (реєстрацію в межах Data Privacy Framework) для низки сервісів. Крім того, Європейська Комісія у 2023 році ухвалила adequacy decision (рішення про адекватність) щодо EU-U.S. Data Privacy Framework.

Висновок:

Некоректно стверджувати, що сьогодні будь-який US vendor (американський постачальник) автоматично перебуває поза правовим полем для роботи з даними з ЄС. Поточна правова рамка є значно складнішою. Водночас для special category data (особливо чутливих даних), зокрема медичних, вибір архітектури все одно має визначальне значення.

4. У чому Salesforce справді сильний

Salesforce має сильні сторони, і їх варто прямо визнати.

4.1 Швидкий старт для CRM

Якщо ціль полягає у швидкому запуску:

- роботи з лідами;
- комерційної воронки;
- стандартної взаємодії з клієнтами;
- базових аналітичних звітів;

тоді Salesforce зазвичай дозволяє стартувати швидше, ніж повністю нова розробка.

4.2 Зріла екосистема

Salesforce - це велика enterprise platform (корпоративна платформа), де вже існують:

- marketplace (ринок додатків і інтеграцій);
- partner ecosystem (екосистема партнерів);
- готові security products (продукти безпеки);
- готові industry clouds (галузеві хмарні продукти).

4.3 Сильний CRM-модуль

Для задач типу:

- lead qualification (кваліфікація лідів);
- pipeline visibility (прозорість воронки);
- sales reporting (звіти продажів);
- account and contact management (робота з контактами і акаунтами);

Salesforce є одним із провідних рішень на ринку для класичних CRM-сценаріїв.

5. Де починається реальна відмінність від звичайного CRM-проєкту

Згідно з підготовленими документами вимог, для роботи системи критично потрібні:

- medical anamnesis (медичний анамнез) з повторюваними блоками;
- pain records (облік болю) зі шкалою NRS;
- specialty sub-flows (підфлоу за медичними напрямками);
- patient-specific access model (модель доступу, прив'язана до пацієнта);
- interpreter workflow (призначення, погодження, звіти, години, білінг);
- concierge workflow (логістика без доступу до діагнозів);

- document sharing policy engine (правила обміну документами);
- German billing logic (німецька логіка білінгу);
- DATEV export (експорт у DATEV);
- patient portal (портал пацієнта);
- follow-up automation (автоматизація післясупроводу).

Це означає, що у цьому випадку CRM - лише один модуль.

Головне ядро системи - це:

- medical operations (медичні операції);
- patient operations (операції навколо пацієнта);
- compliance-aware workflows (процеси з урахуванням регуляторної відповідності);
- finance and document control (фінансовий і документний контур).

6. Детальне порівняння

6.1 Product fit (відповідність продукту)

Критерій	Salesforce як основа	Власна платформа як основа
Lead management (керування лідами)	Сильна сторона	Потрібно будувати
CRM visibility (видимість воронки та контактів)	Сильна сторона	Потрібно будувати
Medical case management (керування медичними кейсами)	Можливо, але через industry products + custom layer	Проектується безпосередньо під цей кейс
Patient operations (операції навколо пацієнта)	Можливо, але не є природним центром платформи	Є природним центром рішення
Domain model fit (відповідність доменній моделі)	Часткова відповідність	Висока відповідність

Висновок:

Salesforce є сильною CRM foundation (CRM-основною), але цільова система в цьому проєкті має бути ширшою за CRM.

6.2 Data residency (локалізація даних) і legal posture (правова рамка)

Критерій	Salesforce	Власна платформа
EU data residency (зберігання і обробка даних у ЄС)	Підтримується для підтримуваних продуктів через Hyperforce EU Operating Zone	Може бути закладена як базовий принцип всієї системи
In-region support (підтримка персоналом у регіоні)	Заявлена для EU OZ	Може бути обмежена обраними постачальниками і командами
International transfer complexity (складність міжнародної передачі даних)	Вища через US vendor profile	Нижча, якщо архітектура і процесори контролюються в ЄС
Processor transparency (прозорість ланцюга обробки)	Частково визначається vendor model	Може бути значно вищою

Висновок:

Salesforce сьогодні має сильніші позиції щодо EU hosting (хостинг у ЄС), ніж часто вважають. Але для чутливих медичних даних власна платформа дає вищий рівень control over the data path (контролю над шляхом проходження даних).

6.3 Encryption and key management (шифрування і керування ключами)

Критерій	Salesforce	Власна платформа
Encryption at rest (шифрування даних у сховищі)	Підтримується через Shield Platform Encryption	Може бути закладено на рівні storage, database і application design
AES-256	Так, офіційно підтримується в Shield	Може бути реалізовано як базова вимога
BYOK, Bring Your Own Key (власні ключі замовника)	Підтримується	Може бути закладено як customer-controlled key model
Key lifecycle control (керування життєвим циклом ключів)	В межах моделі Salesforce	Визначається цільовою архітектурою і обраною KMS/HSM-моделлю

Висновок:

Salesforce має сильний encryption layer (шар шифрування). Власна платформа, своєю чергою, дає змогу контролювати не лише сам факт шифрування, а й загальну key governance model (модель керування ключами).

6.4 Auditability (аудитованість) і monitoring (моніторинг)

Критерій	Salesforce	Власна платформа
Event monitoring (моніторинг подій)	Підтримується через Shield	Може бути спроектований під конкретні доменні події системи
Field history / long-term audit (довгострокова історія змін)	Підтримується через Field Audit Trail	Може бути повністю узгоджена з доменною моделлю
Compliance reporting (звітність для регуляторної відповідності)	Частково підтримується platform tools	Може бути побудована exactly for this process (точно під цей процес)
Domain-level audit (аудит на рівні бізнес-правил)	Потребує додаткового проектування поверх платформи	Закладається в core design (ядро дизайну)

Висновок:

Salesforce дає сильні базові audit tools (інструменти аудиту). Власна платформа виграє там, де важливий не лише platform audit (аудит платформи), а саме domain audit (аудит доменних дій): хто відкрив медичний документ, хто дав freigabe, хто переслав документ провайдеру, хто змінив billing item (пункт білінгу) тощо.

6.5 Access control (контроль доступу)

Цільова модель доступу в цьому проєкті визначена так:

role + assignment + data sensitivity + share status

Це означає, що система має враховувати:

1. роль користувача;
2. чи призначено йому конкретного пацієнта;
3. який тип даних відкривається;
4. чи дозволено взагалі перегляд або sharing (обмін) цього об'єкта.

Критерій	Salesforce	Власна платформа
Role-based access control, RBAC (рольовий доступ)	Так	Так

Критерій	Salesforce	Власна платформа
Context-based access control (контекстний доступ)	Можливо, але складно	Проектується як first-class rule (базове правило системи)
Need-to-know model (принцип "лише потрібний доступ")	Можливо	Може бути ядром архітектури
Fine-grained sharing rules (дрібнозернисті правила доступу)	Можливі, але зростає складність	Природно реалізуються в доменній моделі

Висновок:

Для 10-рівневої роле-чутливої моделі доступу у медичному середовищі власна платформа має сильнішу позицію саме через можливість зробити access logic (логіку доступу) частиною домену, а не нашаруванням platform permissions (дозволів платформи).

6.6 Medical workflow fit (відповідність медичному процесу)

Питання	Salesforce	Власна платформа
Complex anamnesis (складний анамнез)	Потребує кастому	Реалізується прямо за погодженою специфікацією
Repeatable blocks (повторювані блоки)	Можливо, але складно	Природна відповідність
Pain scoring (оцінка болю)	Переважно custom	Природна відповідність
Specialty flows (підфлоу за напрямками)	Переважно custom	Природна відповідність
Medical summary for provider (резюме для провайдера)	Можливо, але через кастом	Вбудовується в процес

Висновок:

Саме в medical workflow (медичному процесі) власна платформа демонструє одну з ключових переваг.

6.7 Documents and sharing (документи і правила обміну)

У цьому випадку документ - це не просто file attachment (вкладений файл), а керований об'єкт із такими властивостями:

- category (категорія);
- source (джерело);
- status (статус);

- visibility (видимість);
- version history (історія версій);
- share eligibility (дозволеність зовнішнього обміну);
- allowed channel (дозволений канал);
- audit trail (аудит дій).

Критерій	Salesforce	Власна платформа
Зберігання документів	Так	Так
Metadata-driven document lifecycle (життєвий цикл документа через метадані)	Можливо, але складно	Природна відповідність
Medical-only routing (медичний документ лише медичному партнеру)	Потрібен custom rule engine	Проектується як core behavior (базова поведінка)
Audit on sharing (аудит кожної відправки)	Можливо	Проектується прямо в доменну модель

Висновок:

Для медичної агенції такого типу document governance (керування документами) є сильним аргументом на користь власної платформи.

6.8 Billing and finance (білінг і фінанси)

Вимоги цього проєкту включають:

- VAT rules (правила ПДВ);
- prepayments (передоплати);
- interim invoices (проміжні рахунки);
- Mahnwesen / dunning workflow (процес нагадувань про оплату);
- DATEV export (експорт у DATEV);
- pass-through expenses (витрати, що передаються 1:1);
- order-based invoicing (рахунки в прив'язці до замовлення);
- billing lines from interpreter / concierge / PM activity (білінгові рядки з операційних дій).

Критерій	Salesforce	Власна платформа
Standard CRM billing fit (відповідність стандартному CRM-білінгу)	Часткова відповідність	Не головний критерій
German billing contour (німецький фінансовий)	Слабка відповідність, потребує кастому та	Сильна відповідність, якщо будувати від вимог

Критерій	Salesforce	Власна платформа
контур)	інтеграцій	
DATEV export	Not core capability	Може бути закладений як базовий модуль
Order-to-invoice traceability (простежуваність від замовлення до рахунку)	Можлива, але складна	Природна частина моделі

Висновок:

Billing є однією з ключових причин на користь власної платформи, якщо саме вона розглядається як операційне ядро системи.

6.9 Responsibility and liability (відповідальність і юридичний ризик при витоку даних)

Це один із ключових розділів для прийняття рішення.

Базове правило GDPR (Загального регламенту захисту даних)

У більшості таких сценаріїв медична агенція виступає data controller (контролером даних), тобто саме вона визначає:

- навіщо обробляються дані;
- які саме дані обробляються;
- кому і коли вони відкриваються;
- як довго вони зберігаються.

Постачальник платформи, як правило, виступає data processor (процесором даних) або sub-processor (субпроцесором).

Практичне значення

У випадку personal data breach (витоку або іншого інциденту з персональними даними):

- регулятор насамперед дивиться на controller (контролера даних);
- постраждалі особи також зазвичай пред'являють претензії насамперед до controller;
- processor (процесор) теж може нести відповідальність, але це **не прибирає** відповідальність з controller.

Ключовий висновок:

Жодна модель не дає можливості пообіцяти клієнту, що "йому точно нічого не буде". Якщо агенція є controller (контролером даних), повністю винести ризик назовні юридично неможливо.

Salesforce scenario (сценарій із Salesforce)

У моделі з Salesforce:

- агенція майже напевно залишається controller;
- Salesforce виступає processor для відповідних сервісів;
- при інциденті велику роль відіграватимуть умови DPA (угоди про обробку даних), contractual liability caps (ліміти відповідальності за договором), перелік subprocessors і фактична архітектура сервісів.

Перевага цього підходу:

- великий vendor;
- зрілі формальні security і privacy програми;
- готові contractual frameworks.

Слабке місце цього підходу:

- менше простору для індивідуального перерозподілу відповідальності;
- стандартні умови великого vendor зазвичай значно більше захищають самого vendor, ніж замовника;
- у замовника менше контролю над фактичним технічним контуром.

Custom platform scenario (сценарій із власною платформою)

У моделі з власною платформою можливі два різні підходи.

Варіант 1. Замовник володіє і контролює систему сам

Якщо:

- система розгорнута на акаунті замовника;
- ключі шифрування контролює замовник;
- доступ до production (продуктивного середовища) контролює замовник;
- підрядник лише розробляє або обмежено супроводжує;

тоді відповідальність і контроль сильніше концентруються у самого замовника.

Перевага:

- максимум технічного контролю;
- мінімум зовнішніх залежностей;
- прозора архітектура.

Недолік:

- замовник несе ще більше прямої операційної відповідальності;
- при інциденті неможливо сказати, що "це повністю проблема платформи постачальника".

Варіант 2. Підрядник не лише будує, а й керовано супроводжує платформу

Якщо підрядник:

- має production obligations (обов'язки щодо продуктивного середовища);
- відповідає за monitoring (моніторинг), security patching (оновлення безпеки), incident response (реагування на інциденти), backup (резервування) або hosting operations (операційну частину хостингу);

тоді з'являється більше підстав для:

- чіткого розподілу відповідальності в договорі;
- breach notification obligations (обов'язків щодо повідомлення про інцидент);
- indemnity clauses (умов про відшкодування збитків);
- professional liability / cyber insurance (професійного страхування відповідальності / кіберстрахування).

Перевага:

- можна значно точніше прописати, хто за що відповідає;
- можна закласти SLA (угоду про рівень сервісу), incident handling obligations (обов'язки щодо реагування на інциденти), logging, escalation path (ескалацію), audit rights (права аудиту) і contractual remedies (договірні механізми захисту).

Недолік:

- навіть тут controller-ризик у замовника не зникає повністю.

Рекомендоване формулювання для клієнта

Правильно казати не так:

"У custom platform (власній платформі) ризику для замовника немає."

А так:

"У моделі власної платформи ризик для замовника як controller (контролера даних) не зникає, однак сторони можуть значно точніше розподілити технічну, операційну і договірну відповідальність, ніж у великій стандартній SaaS-платформі. Крім того, замовник отримує більше контролю над архітектурою, доступами, ключами шифрування, колом subprocessors (субпроцесорів) і фактичним data path (шляхом проходження даних)."

Практичне значення для відповідальності сторін

Для практичного розуміння:

- data subjects (суб'єкти даних) і regulator (регулятор) зазвичай перш за все дивляться на controller;

- controller потім може звертатися з recourse claim (регресною вимогою) до processor або іншої сторони, якщо саме вона спричинила або посилила порушення;
- тому для замовника ключове питання не "чи можна зробити так, щоб відповідальності взагалі не було", а "чи можна зробити так, щоб контроль, докази, договірний захист і можливість пред'явити регресну вимогу були максимально сильними".

Висновок

Для клієнта, який прагне максимально контрольованої та прозорої моделі ризику, власна платформа може мати перевагу **не через усунення відповідальності**, а завдяки тому, що вона дає змогу:

- краще контролювати архітектуру;
- скоротити коло subprocessors (субпроцесорів);
- визначити чіткі security obligations (обов'язки з безпеки);
- узгодити incident response (реагування на інциденти);
- зафіксувати contractual liability (договірну відповідальність) більш адресно;
- отримати більш дієвий recourse path (механізм регресної вимоги), якщо постачальник реально бере на себе частину операційного ризику.

6.10 Vendor lock-in (залежність від постачальника)

Критерій	Salesforce	Власна платформа
Platform dependency (залежність від екосистеми)	Висока	Нижча
Code portability (портативність коду)	Нижча	Вища
Data portability (портативність даних)	Можлива, але доменна логіка залишається сильно пов'язаною з платформою	Визначається вами
Negotiation leverage (переговорна позиція)	Нижча	Вища

Висновок:

Чим більше критичного бізнес-процесу будується всередині Salesforce, тим вищою стає не лише технічна, а й комерційна залежність від vendor ecosystem (екосистеми постачальника).

6.11 Time to value (час до корисного результату)

Критерій	Salesforce	Власна платформа
Швидкість запуску базового CRM	Вища	Нижча
Швидкість запуску exact-fit medical operations (точної медичної операційної моделі)	Часто нижча через кастом	Часто вища після фази проектування
Predictability of final fit (передбачуваність кінцевої відповідності)	Нижча, якщо домен дуже специфічний	Вища

Висновок:

Salesforce швидше запускає стандартний CRM. Власна платформа частіше швидше приводить саме до правильної цільової системи, якщо бізнес-процес нестандартний і дуже специфічний.

7. Фінансовий блок

Total cost of ownership, TCO (повна вартість володіння) потрібно подавати дуже обережно.

Що можна стверджувати обґрунтовано вже зараз

Для Salesforce модель витрат, як правило, включає:

- ліцензії;
- додаткові security products (продукти безпеки);
- healthcare products (галузеві продукти для медицини);
- implementation partner cost (вартість впровадження партнером);
- integrations (інтеграції);
- ongoing administration (постійну адміністрацію і підтримку).

Для власної платформи модель витрат, як правило, включає:

- початкову розробку;
- cloud infrastructure (хмарну інфраструктуру);
- support and maintenance (підтримку і супровід);
- legal / compliance work (юридичну підготовку і підготовку з регуляторної відповідності);
- окремі інтеграції.

Entry cost (вартість входу в Salesforce)

За офіційно опублікованими цінами Salesforce станом на 2026 рік:

- Sales Cloud Starter Suite (стартовий CRM-рівень) - **\$25 за користувача на місяць, billed annually** (з річною оплатою);

- Sales Cloud Enterprise (корпоративний CRM-рівень) - **\$175 за користувача на місяць**, billed annually;
- Sales Cloud Unlimited - **\$350 за користувача на місяць**, billed annually;
- Health Cloud Enterprise - **\$350 за користувача на місяць**, billed annually;
- Health Cloud Unlimited - **\$525 за користувача на місяць**, billed annually.

Окремо Salesforce Shield публікується як percentage-of-net-spend pricing (модель ціноутворення як відсоток від чистих витрат на ліцензії):

- Shield bundle - **30% of net spend**;
- Platform Encryption - **20% of net spend**;
- Event Monitoring - **10% of net spend**;
- Field Audit Trail - **10% of net spend**.

Висновок:

Навіть до початку кастомної розробки вартість входу в Salesforce для медичного сценарію зазвичай означає не лише базову CRM-ліцензію, а комбінацію:

- core CRM license (основної CRM-ліцензії);
- healthcare license (галузевої медичної ліцензії), якщо потрібен Health Cloud;
- security add-ons (додаткових модулів безпеки), якщо потрібні шифрування, аудит і моніторинг;
- implementation cost (вартості впровадження).

Який висновок коректний без спекуляцій

Для простого CRM-сценарію Salesforce часто дешевший на старті.

Для вузькоспеціалізованої операційної платформи з:

- медичним контуром;
- document governance;
- німецьким billing contour;
- role-sensitive workflows;

Salesforce часто переходить у дорожчий сценарій через поєднання:

- recurring licenses (регулярних ліцензійних платежів);
- premium add-ons (додаткових преміум-модулів);
- partner customizations (кастомізації партнером);
- platform-specific maintenance (супроводу специфічно під платформу).

Що варто винести в окремий фінансовий додаток

Для PDF-пакета доцільно робити окремий appendix (додаток) з assumptions (вихідними припущеннями):

- кількість користувачів;
 - які продукти Salesforce припускаються;
 - чи потрібен Shield;
 - чи потрібен Health Cloud;
 - чи потрібні окремі продукти для e-signature (е-підпису), billing, portal, integrations;
 - що включено в custom build;
 - що включено в annual support (річну підтримку).
-

8. Технологічна безпека

Ключовий висновок для клієнта полягає в наступному:

Безпека системи визначається не однією мовою програмування і не однією хмарою, а сукупністю рішень:

- architecture (архітектури);
- encryption boundaries (меж шифрування);
- access control (контролю доступу);
- auditability (аудитованості);
- backup and recovery (резервування та відновлення);
- data minimization (мінімізації даних на клієнтських інтерфейсах).

Що можна обґрунтовано сказати про власну платформу

Власна платформа має перевагу не через окрему технологію саму по собі, а завдяки тому, що дає змогу:

- контролювати, які саме дані сервер узагалі віддає клієнтському інтерфейсу;
 - зробити authorization model (модель авторизації) доменною;
 - побудувати audit trail (журнал аудиту) під конкретні правила системи;
 - поєднати document sharing rules (правила обміну документами), consent model (модель згод) і billing model (фінансову модель) в одному керованому контурі.
-

9. Варіанти рішення

9.1 Salesforce-centric model (модель із Salesforce як ядром)

Підходить, якщо компанія хоче:

- швидкий CRM-старт;
- сильний lead management;
- мінімум спеціалізованого медичного процесу;
- прийняти higher platform dependency (вищу залежність від платформи).

9.2 Custom-core model (модель із власною платформою як ядром)

Підходить, якщо компанія хоче:

- повністю контролювати patient operations (операції навколо пацієнта);
- закласти медичний і документний контур як core design (ядро дизайну);
- реалізувати німецький billing contour як first-class module (базовий модуль);
- зменшити vendor lock-in;
- контролювати storage, encryption, audit і access rules на рівні архітектури.

9.3 Hybrid model (гібридна модель)

Окремо може розглядатися і hybrid model (гібридна модель):

- Salesforce використовується для marketing CRM (маркетингового CRM) і lead management;
- власна платформа використовується для medical operations (медичних операцій), documents (документів), billing (білінгу), portal (порталу) і compliance-aware workflows (процесів з урахуванням регуляторної відповідності).

Такий підхід дає змогу:

- не відмовлятися від сильних сторін Salesforce;
- не намагатися зробити з CRM ядро медичної операційної системи;
- зберегти більш чисту і керовану архітектуру.

10. Підсумкова таблиця для клієнта

Критерій	Salesforce як основа	Власна платформа як основа	Короткий висновок
CRM / lead management (робота з лідами)	Сильна сторона	Потрібно будувати	Перевага Salesforce
Medical case management (керування медичним кейсом)	Можливо, але складно	Проектується безпосередньо під процес	Перевага власної платформи
Data residency (локалізація даних)	Сильні EU-опції для підтримуваних сервісів	Повний контроль над архітектурою розміщення	Нічия на рівні базових можливостей, перевага власної

Критерій	Salesforce як основа	Власна платформа як основа	Короткий висновок
			платформи у рівні контролю
Encryption / BYOK (шифрування / власні ключі)	Підтримується	Підтримується за рахунок архітектури	Нічия по базових можливостях, перевага custom у глибині контролю
Context-based access (контекстний доступ)	Можливий, але складний	Природна частина дизайну	Перевага власної платформи
Document governance (керування документами)	Часткова відповідність	Сильна відповідність	Перевага власної платформи
German billing contour (білінг за німецькими правилами)	Складна відповідність	Сильна відповідність	Перевага власної платформи
Vendor lock-in (залежність від постачальника)	Високий	Нижчий	Перевага власної платформи
Time to first CRM value (час до першої CRM-користі)	Швидше	Повільніше	Перевага Salesforce
Long-term operational fit (довгострокова відповідність операційній моделі)	Обмежена для такого кейсу	Висока	Перевага власної платформи

11. Рекомендація

Для медичної агенції такого типу базовий висновок може бути сформульований так:

Salesforce є сильною CRM-платформою і може бути корисним інструментом для lead management та частини комерційних процесів. Але якщо потрібне ядро системи для роботи з медичними даними пацієнтів, складними рольовими доступами, документами, німецьким білінгом і процесами між клініками, перекладачами, concierge та бухгалтерією, то власна платформа є більш відповідною довгостроковою основою.

У більш стислому вигляді:

Для цього бізнесу CRM є лише одним із модулів. Тому рішення доцільно приймати не за принципом "CRM проти не-CRM", а за принципом "що буде ядром операційної медичної системи". На цьому рівні власна платформа має вищу відповідність цільовій моделі.

Окремо, якщо компанія захоче поєднати сильні сторони обох підходів, може розглядатися hybrid model (гібридна модель):

- Salesforce для лідів і маркетингового CRM;
- власна платформа для patient operations (операцій навколо пацієнта), medical data (медичних даних), documents (документів), billing (білінгу) і portal (порталу).

12. Юридичні та договірні питання, які потребують окремого підтвердження

Цей документ є стратегічним і технологічним порівнянням. Перед фінальним рішенням рекомендовано окремо підтвердити з профільним юристом і, за потреби, зовнішнім консультантом такі питання:

1. як саме для обраного сценарію оцінюються вимоги Art. 9 DSGVO щодо special category data (особливо чутливих даних);
2. чи потрібен DPIA, Data Protection Impact Assessment (оцінка впливу на захист даних), і який висновок він дає для кожного з підходів;
3. на яких підставах оформлюється DPA, Data Processing Agreement (угода про обробку даних), а також, якщо це потрібно, SCC, Standard Contractual Clauses (стандартні договірні положення);
4. як саме застосовується DPF, Data Privacy Framework (рамка правомірної передачі даних) до конкретних сервісів, які реально планується використовувати;
5. які subprocessors (субпроцесори) беруть участь у хостингу, підтримці, інтеграціях, e-signature (е-підписі), email (електронній пошті), payment processing (обробці оплат) та аналітиці;
6. де саме розміщуються дані, резервні копії, журнали аудиту та ключі шифрування;
7. який deletion and retention model (порядок видалення і зберігання даних) є юридично та операційно допустимим;
8. хто саме є controller (контролером даних), processor (процесором) і, за потреби, subprocessor (субпроцесором) у кожному сценарії;
9. хто і в які строки зобов'язаний виконувати breach notification (повідомлення про інцидент) до регулятора та суб'єктів даних;
10. які liability caps (ліміти відповідальності), indemnities (умови відшкодування), audit rights (права аудиту) і insurance coverage (страхове покриття) передбачаються договорами;
11. чи відповідає обрана архітектура вимогам regulator-facing documentation (документації для регулятора), якщо її потрібно буде показувати наглядовому органу.

13. Додаткові appendices (додатки)

- [docs/comparison/cover-page.md](#) - титульна сторінка PDF-пакета
 - [docs/comparison/release-package-index.md](#) - титульний індекс релізного пакета
 - [docs/comparison/legal-risk-appendix.md](#) - окремий додаток по [controller](#) / [processor](#) / [liability](#) / [breach response](#)
 - [docs/comparison/custom-platform-contract-checklist.md](#) - checklist для договору по власній платформі
 - [docs/comparison/tco-financial-appendix.md](#) - фінансовий додаток із published pricing і entry cost scenarios
-

14. Публічні джерела, перевірені станом на квітень 2026 року

Salesforce

1. Salesforce Hyperforce EU Operating Zone:
salesforce.com/platform/data-residence-eu-oz
2. Salesforce Shield Guide:
salesforce.com/platform/shield/guide
3. Salesforce Health Cloud Overview:
salesforce.com/products/health-cloud/overview
4. Salesforce Data Privacy Framework Registration:
compliance.salesforce.com
5. Salesforce Sales Cloud Pricing:
salesforce.com/sales/pricing
6. Salesforce Health Cloud Pricing:
salesforce.com/healthcare-life-sciences/health-cloud/pricing
7. Salesforce Shield Pricing:
salesforce.com/platform/shield/pricing

Європейська Комісія

8. EU-U.S. Data Privacy Framework adequacy decision:
commission.europa.eu
9. GDPR, Regulation (EU) 2016/679:
eur-lex.europa.eu

EDPB

10. European Data Protection Board: Data controller or data processor:
edpb.europa.eu
11. European Data Protection Board: Data breaches:
edpb.europa.eu

AWS

12. AWS Cloud Computing Compliance Criteria Catalogue (C5):

aws.amazon.com/compliance/bsi-c5

Оновлено: Квітень 2026

tco-financial-appendix.md

Підготував: Dr. Oleksandr Melnychenko, CEO at [Horizon Dynamics](#)

TCO and Entry Cost Appendix

Фінансовий додаток до документа `salesforce-vs-custom-platform.md`. Цей матеріал побудований на публічно доступних published pricing (опублікованих цінах) Salesforce станом на квітень 2026 року. Документ не є комерційною офертою і не замінює фінальний кошторис.

Статус документа

- Версія: `Release Draft`
- Формат: `Client-facing appendix`
- Дата підготовки: `Квітень 2026`

1. Мета документа

Цей додаток відповідає на два питання:

- скільки коштує entry cost (вартість входу) в Salesforce за офіційно опублікованими тарифами;
- як виглядає recurring cost baseline (базовий регулярний ліцензійний витратний контур) для різних сценаріїв.

Важливо:

- це **не повний TCO** у фінальному значенні;
- це published-price baseline (базовий розрахунок на основі публічних цін);
- implementation (впровадження), partner work (роботи партнера), integrations (інтеграції), support (підтримка), e-signature, billing extensions, portal, DATEV logic і custom workflows у цей baseline **не входять**, якщо для них немає офіційного опублікованого прайсу.

2. Офіційні published pricing (опубліковані ціни), що використані в розрахунках

Salesforce Sales Cloud

- Sales Cloud Starter Suite - **\$25 / user / month**
- Sales Cloud Enterprise - **\$175 / user / month**
- Sales Cloud Unlimited - **\$350 / user / month**

Salesforce Health Cloud

- Health Cloud Enterprise - **\$350 / user / month**
- Health Cloud Unlimited - **\$525 / user / month**

Salesforce Shield

Shield опублікований як percentage-of-net-spend pricing (модель ціни як відсоток від чистих витрат на ліцензії):

- Shield bundle - **30% of net spend**
- Platform Encryption - **20% of net spend**
- Event Monitoring - **10% of net spend**
- Field Audit Trail - **10% of net spend**

Важливе уточнення

У цьому документі всі розрахунки робляться:

- у **USD** ;
- без ПДВ;
- без знижок;
- без контрактних спецумов;
- для billed annually scenarios (сценаріїв із річною оплатою), де це вимагає тариф.

3. Чому саме ці сценарії мають значення

Для медичної агенції доцільно розглядати щонайменше чотири базові сценарії входу у Salesforce.

Scenario A. CRM-only baseline (лише CRM-база)

Використовується тільки Sales Cloud Enterprise.

Цей сценарій показує:

- мінімальну адекватну CRM-вартість для серйозного B2B/B2C процесу;
- але **не** покриває медичний контур.

Scenario B. Healthcare baseline (медичний базовий контур)

Використовується Health Cloud Enterprise.

Цей сценарій показує:

- скільки коштує вхід уже на healthcare-рівні;
- але ще **без** повного Shield security layer (повного шару безпеки Shield).

Scenario C. Healthcare + Shield baseline

Використовується Health Cloud Enterprise + Shield bundle.

Цей сценарій є одним із найбільш релевантних для regulated data scenario (сценарію з регульованими даними), оскільки показує вартість входу, якщо потрібні:

- encryption;
- field audit;
- event monitoring;
- sensitive data controls.

Scenario D. Higher-end healthcare baseline

Використовується Health Cloud Unlimited + Shield bundle.

Це сценарій для випадку, коли потрібен вищий функціональний і сервісний рівень платформи.

4. Формули розрахунку

Monthly formula (місячна формула)

Monthly Cost = Price per User per Month x Number of Users

Annual formula (річна формула)

Annual Cost = Monthly Cost x 12

Shield formula (формула для Shield)

Shield Cost = 30% x Net Salesforce License Spend

5. Entry cost scenarios (сценарії вартості входу)

5.1 Scenario A — Sales Cloud Enterprise only

Тариф:

- \$175 / user / month
- \$2,100 / user / year

Кількість користувачів	Місячна вартість	Річна вартість
10	\$1,750	\$21,000
15	\$2,625	\$31,500
20	\$3,500	\$42,000

Коментар

Це корисний орієнтир для CRM-сценарію, але він не показує реальну вартість медичного контуру.

5.2 Scenario B — Health Cloud Enterprise only

Тариф:

- \$350 / user / month
- \$4,200 / user / year

Кількість користувачів	Місячна вартість	Річна вартість
10	\$3,500	\$42,000
15	\$5,250	\$63,000
20	\$7,000	\$84,000

Коментар

Це вже значно реалістичніша точка входу для healthcare-shaped scenario (сценарію, схожого на медичний), але ще без повного Shield security stack (стека безпеки Shield).

5.3 Scenario C — Health Cloud Enterprise + Shield bundle

Health Cloud Enterprise:

- \$350 / user / month

Shield bundle:

- 30% of net spend

Ефективна місячна вартість на 1 користувача:

- $\$350 + 30\% = \455 / user / month

Ефективна річна вартість на 1 користувача:

- $\$455 \times 12 = \$5,460$ / user / year

Кількість користувачів	Місячна вартість	Річна вартість
10	\$4,550	\$54,600
15	\$6,825	\$81,900
20	\$9,100	\$109,200

Коментар

Це один із ключових орієнтирів для реалістичного regulated healthcare scenario (сценарію з регульованими медичними даними), оскільки він показує:

- не тільки healthcare license;
- а й security and audit baseline (базовий безпековий та аудиторський шар).

5.4 Scenario D — Health Cloud Unlimited + Shield bundle

Health Cloud Unlimited:

- \$525 / user / month

Shield bundle:

- 30% of net spend

Ефективна місячна вартість на 1 користувача:

- $\$525 + 30\% = \682.50 / user / month

Ефективна річна вартість на 1 користувача:

- $\$682.50 \times 12 = \$8,190$ / user / year

Кількість користувачів	Місячна вартість	Річна вартість
10	\$6,825	\$81,900
15	\$10,237.50	\$122,850
20	\$13,650	\$163,800

Коментар

Це вже high-end baseline (високий базовий сценарій) і його варто розглядати, якщо реально потрібен підвищений platform tier (рівень платформи), більший сервісний пакет і ширший enterprise contour (корпоративний контур).

6. Що в цих цифрах ще НЕ враховано

Навіть у Scenario C або D ці цифри **не є повним TCO**. У них ще не враховано:

- implementation partner fees (вартість партнера з впровадження);
- solution design and architecture work (проектування рішення і архітектури);
- custom development (кастомну розробку);
- integrations (інтеграції);

- patient portal (портал пацієнта);
 - custom billing logic (кастомну білінгову логіку);
 - document governance layer (документний контур);
 - e-signature provider cost (вартість провайдера електронного підпису);
 - email / communication tooling;
 - internal admin / devops / support cost;
 - ongoing customization and maintenance (подальшу підтримку і кастомізацію).
-

7. Практичне значення

7.1 Мінімальний чесний висновок

Для медичної агенції важливо не плутати:

- **CRM entry cost** (вартість входу в CRM)
і
- **operational platform cost** (вартість входу в повноцінну операційну платформу).

Salesforce може виглядати дешевше, якщо дивитися тільки на стартову CRM-ліцензію.

Але якщо потрібні:

- healthcare license;
- Shield security layer;
- регуляторна відповідність;
- кастомний document flow;
- кастомний billing contour;
- role-sensitive workflows;

тоді реальний фінансовий контур швидко стає значно ширшим за базову CRM-ціну.

7.2 Рекомендована бізнес-формула

Для такого типу проєкту правильніше дивитися не на:

CRM license only

а на:

License + Security + Healthcare + Customization + Integration + Support

8. Як це порівнювати з власною платформою

Для власної платформи published list pricing (опублікованих стандартних тарифів) зазвичай не існує в тому ж вигляді, як у Salesforce.

Замість цього фінансова модель складається з:

- discovery and architecture (дослідження й архітектури);

- product design (проектування продукту);
- implementation (розробки);
- cloud infrastructure (хмарної інфраструктури);
- support and maintenance (підтримки і супроводу);
- legal / compliance work (юридичної та регуляторної підготовки).

Чому це важливо

У Salesforce значна частина витрат має форму recurring platform fees (регулярних ліцензійних платежів).

У власній платформі значна частина витрат зсунуто:

- у початкову фазу побудови;
- а далі - у support, hosting і контрольовану еволюцію продукту.

Типова різниця між підходами може бути зведена до такої логіки:

- Salesforce: нижчий поріг запуску простого CRM, але часто вищий довгостроковий recurring spend у складних сценаріях;
- custom platform: вищий початковий поріг побудови, але часто нижчий platform lock-in і вищий контроль над подальшою економікою.

9. Що треба уточнити перед фінальним фінансовим порівнянням

Щоб зробити вже остаточний client-ready TCO (готовий до клієнта фінансовий розрахунок), окремо треба зафіксувати:

1. скільки буде named users (іменних користувачів);
2. скільки з них потребують тільки CRM, а скільки - healthcare-tier access;
3. чи потрібен Shield bundle для всіх користувачів або лише для частини;
4. чи потрібні окремі продукти для portal, e-signature, integrations, analytics;
5. який обсяг кастомної логіки реально потрібно реалізовувати в Salesforce;
6. який expected support model (очікуваний формат підтримки) потрібен після запуску;
7. чи потрібно порівнювати:
 - тільки software spend (витрати на ПЗ);
 - чи повний TCO разом із командою, інтеграціями, операціями і юридичною підготовкою.

10. Публічні джерела

1. Salesforce Sales Pricing:
salesforce.com/sales/pricing

2. Salesforce Health Cloud Pricing:

salesforce.com/healthcare-life-sciences/health-cloud/pricing

3. Salesforce Shield Pricing:

salesforce.com/platform/shield/pricing

Оновлено: Квітень 2026

legal-risk-appendix.md

Підготував: Dr. Oleksandr Melnychenko, CEO at [Horizon Dynamics](#)

Legal Risk Appendix

Додаток до документа `salesforce-vs-custom-platform.md`. Матеріал підготовлений для бізнес-оцінки ризиків і не є індивідуальною юридичною консультацією. Перед фінальним рішенням документ має бути перевірений німецьким юристом з `GDPR / DSGVO`, `IT-Recht` і `B2B contracting`.

Статус документа

- Версія: `Release Draft`
- Формат: `Client-facing appendix`
- Дата підготовки: `Квітень 2026`

1. Мета документа

Цей додаток пояснює одне з ключових питань, яке зазвичай виникає у керівництва:

Якщо станеться `personal data breach` (витік персональних даних), хто нестиме відповідальність?

Ключова ідея:

- жодна архітектура не прибирає ризик повністю;
- але різні архітектури по-різному розподіляють:
- контроль;
- обов'язки;
- доказову базу;
- договірну відповідальність;
- можливість регресу.

2. Базова правова логіка

2.1 Controller (контролер даних)

У типовому сценарії медична агенція є `data controller` (контролером даних), тому що саме вона вирішує:

- навіщо обробляються дані пацієнтів;
- які дані обробляються;
- кому і в яких випадках вони відкриваються;
- скільки часу вони зберігаються;
- які бізнес-процеси запускаються на підставі цих даних.

2.2 Processor (процесор даних)

Data processor (процесор даних) обробляє дані від імені контролера на підставі договору та інструкцій.

У практиці це може бути:

- SaaS vendor (SaaS-постачальник);
- hosting provider (хостинг-провайдер);
- implementation partner (партнер із впровадження);
- managed operations provider (провайдер, який супроводжує продуктивне середовище).

2.3 Sub-processor (субпроцесор)

Sub-processor (субпроцесор) - це інша сторона, яку processor залучає до окремої частини обробки даних.

Наприклад:

- cloud infrastructure provider (хмарний провайдер);
- email delivery provider (провайдер доставки email);
- e-signature provider (провайдер електронного підпису);
- payment provider (провайдер платежів);
- logging / monitoring vendor (провайдер моніторингу).

3. Що відбувається при data breach (витоку даних)

У випадку витоку або іншого серйозного інциденту:

- регулятор насамперед дивиться на **controller** (контролера);
- data subjects (суб'єкти даних) зазвичай теж ідуть насамперед до контролера;
- processor також може нести відповідальність, але це **не звільняє** контролера автоматично.

Тому твердження, що всю відповідальність можна повністю перекласти на платформу, є юридично некоректним.

Правильна формула інша:

Ризик не зникає, але його можна краще контролювати, документувати і договірно розподіляти.

4. Salesforce scenario (сценарій із Salesforce)

4.1 Типова модель

У такому сценарії:

- агенція є `controller` (контролером даних);
- Salesforce є `processor` (процесором даних) для відповідних сервісів;
- додаткові продукти, інтеграції та `partner implementations` можуть створювати додатковий ланцюг `subprocessors`.

4.2 Сильні сторони

- великий vendor із розвиненими security, privacy і compliance programs;
- стандартні `DPA, Data Processing Agreement` (угоди про обробку даних);
- готові audit/security products;
- формально зрілий vendor risk framework.

4.3 Обмеження

- замовник зазвичай не може істотно переписати стандартну liability model (модель відповідальності) великого vendor;
- складніше індивідуально погодити:
- розширені audit rights (права аудиту);
- індивідуальні liability caps (ліміти відповідальності);
- спеціальні indemnities (відшкодування);
- технічні зобов'язання поза межами стандартної моделі сервісу;
- при складній архітектурі з кількома продуктами та інтеграціями зростає складність доказування, де саме виникла причина порушення.

4.4 Висновок

Використання Salesforce не означає відсутності відповідальності у замовника.

Базова логіка полягає в наступному:

- замовник усе одно лишається головною юридично видимою стороною;
- просто частина технічного та операційного ризику знаходиться всередині великої закритої vendor-екосистеми.

5. Custom platform scenario (сценарій із власною платформою)

Тут можливі дві різні моделі.

5.1 Customer-controlled deployment (розгортання під повним контролем замовника)

Якщо:

- інфраструктура належить замовнику;
- production access (доступ до продуктивного середовища) контролює замовник;
- ключі шифрування контролює замовник;
- підрядник лише будує систему або має мінімальний доступ;

то замовник отримує максимальний контроль, але також бере на себе більшу частину прямої операційної відповідальності.

Плюси

- максимальна прозорість;
- мінімум прихованих vendor-залежностей;
- сильна керованість інфраструктури, ключів і логів.

Мінуси

- неможливо стверджувати, що при інциденті винен буде "хтось інший";
- замовник повинен мати сильний операційний контур управління безпекою.

5.2 Managed custom platform (власна платформа з керованим супроводом)

Якщо підрядник або окремий провайдер бере на себе:

- hosting operations (операційне керування хостингом);
- monitoring (моніторинг);
- incident response (реагування на інциденти);
- backup and recovery (резервування і відновлення);
- patching and security maintenance (оновлення та підтримку безпеки);

то з'являється більше простору для чіткого contract-based allocation of risk (договірного розподілу ризику).

Плюси

- можна точніше прописати обов'язки;
- можна вимагати:
- SLA (угоду про рівень сервісу);
- reporting timelines (строки звітності);
- breach notification workflow (порядок повідомлення про інцидент);
- audit rights (права аудиту);
- liability clauses (умови відповідальності);

- insurance obligations (вимоги до страхового покриття).

Мінуси

- навіть у цьому випадку controller-ризик у замовника не зникає;
 - якість захисту залежить від того, наскільки добре сформульований договір.
-

6. Кого "судять" на практиці

Це питання ставиться регулярно, тому відповідь має бути максимально чіткою.

6.1 З боку пацієнта

Пацієнт або інший data subject (суб'єкт даних) зазвичай бачить перед собою не SaaS-платформу, а саме:

- клініку;
- агенцію;
- організацію, якій він довірив дані.

Отже, саме controller майже завжди стає першою юридично видимою стороною.

6.2 З боку регулятора

Регулятор також зазвичай дивиться насамперед на controller:

- чи були законні підстави обробки;
- чи були належні technical and organizational measures, TOMs (технічні й організаційні заходи);
- чи є DPA / SCC / DPF / DPIA там, де це потрібно;
- чи було вчасне breach notification (повідомлення про інцидент);
- чи були обмежені доступи;
- чи була логована обробка;
- чи були належні процеси delete / retain / share.

6.3 Де тоді перевага custom platform

Перевага власної платформи полягає не в тому, що вона усуває відповідальність замовника. Перевага полягає в тому, що у правильно побудованій custom platform model (моделі власної платформи) можна значно точніше визначити:

- хто відповідає за інфраструктуру;
- хто відповідає за доступи;
- хто відповідає за ключі шифрування;
- хто відповідає за моніторинг і повідомлення про інциденти;
- хто відповідає за резервування, відновлення і журналювання;

- хто і в якому обсязі несе договірну відповідальність, якщо порушення сталося з вини конкретної сторони.

Це дає замовнику:

- більш сильну доказову базу;
- більш прозору architecture of responsibility (архітектуру відповідальності);
- більш надійний договірний захист;
- більш дієву можливість пред'явити регресну вимогу до сторони, яка реально порушила свої обов'язки.

7. Що означає "максимально захистити клієнта"

Оскільки пообіцяти "10000% гарантію" неможливо, реальна стратегія захисту має складатися з чотирьох шарів.

7.1 Architecture control (архітектурний контроль)

- чітко визначений hosting region (регіон хостингу);
- контрольований список subprocessors (субпроцесорів);
- customer-controlled keys (власні ключі замовника) або дуже чітка key governance model;
- централізований audit trail;
- мінімізація даних у клієнтських інтерфейсах.

7.2 Operational control (операційний контроль)

- documented incident response process (задокументований процес реагування на інциденти);
- logging and monitoring (логування і моніторинг);
- role-based and context-based access control (рольовий і контекстний доступ);
- backup, recovery, restore testing (резервування, відновлення, тестування відновлення).

7.3 Contract control (договірний контроль)

- чіткий DPA;
- чіткий security schedule (додаток по безпеці);
- breach notification obligations;
- liability allocation;
- indemnities;
- audit rights;
- insurance requirements.

7.4 Legal control (юридичний контроль)

- DPIA;
- vendor review;
- subprocessors review;
- retention/deletion legal review;
- lawful transfer mechanism review;
- jurisdiction and dispute resolution review.

8. Клієнтське формулювання

Для клієнтського документа доцільно використовувати таке формулювання:

У моделі власної платформи ризик для замовника як controller (контролера даних) не зникає, однак сторони можуть значно точніше розподілити технічну, операційну та договірну відповідальність, ніж у великій стандартній SaaS-моделі. Крім того, замовник отримує більше контролю над архітектурою, доступами, ключами шифрування, колом subprocessors (субпроцесорів) і фактичним шляхом проходження даних.

У більш стислому вигляді:

При обробці медичних даних відповідальність контролера неможливо повністю винести назовні. Тому ключове завдання полягає не в усуненні відповідальності як такої, а в тому, щоб побудувати таку архітектуру, договірну модель і операційний контур, у яких контроль, доказова база, договірний захист і можливість пред'явити регресну вимогу будуть максимально сильними.

Практичне значення для відповідальності сторін

Для практичного розуміння важливо виходити з таких принципів:

- data subjects (суб'єкти даних) і regulator (регулятор) зазвичай насамперед дивляться на controller (контролера даних);
- controller може звертатися з recourse claim (регресною вимогою) до processor (процесора) або іншої сторони, якщо саме її дії чи бездіяльність спричинили або посилили порушення;
- тому для замовника ключове питання полягає не в тому, чи можна повністю прибрати відповідальність, а в тому, чи можна побудувати модель, у якій контроль, докази, договірний захист і можливість пред'явити регресну вимогу будуть максимально надійними.

9. Що потрібно обов'язково перевірити з юристом

Перед фінальним рішенням обов'язково потрібно перевірити:

1. хто саме є controller, processor, sub-processor у кожному сценарії;

2. хто несе primary breach notification obligation (основний обов'язок повідомлення про інцидент);
 3. які liability caps (ліміти відповідальності) будуть у договорі;
 4. чи є indemnity language (умови відшкодування збитків) достатньо сильними;
 5. чи є right to audit (право аудиту) достатнім;
 6. чи є required insurance coverage (необхідне страхове покриття) у кожної сторони;
 7. чи є можливість пред'явити регресну вимогу достатньо практичною, а не лише формальною;
 8. чи відповідає вся схема Art. 9 GDPR / DSGVO , DPIA , DPA , SCC , DPF і локальним вимогам.
-

10. Публічні джерела

1. GDPR, Regulation (EU) 2016/679:
eur-lex.europa.eu
 2. EDPB: Data controller or data processor:
edpb.europa.eu
 3. EDPB: Data breaches:
edpb.europa.eu
 4. Salesforce DPA information and privacy materials:
salesforce.com
-

Оновлено: Квітень 2026

custom-platform-contract-checklist.md

Підготував: Dr. Oleksandr Melnychenko, CEO at [Horizon Dynamics](#)

Custom Platform Contract Checklist

Практичний checklist (чекліст) для договору, якщо обирається власна платформа як ядро системи. Це не юридична консультація, а список тем, які варто узгодити з юристом до підписання договору.

Статус документа

- Версія: Release Draft
- Формат: Client-facing appendix
- Дата підготовки: Квітень 2026

1. Мета документа

Цей документ потрібен для того, щоб у моделі з власною платформою замовник отримав не лише результат розробки, а й:

- зрозумілий розподіл відповідальності;
- належний договірний захист;
- керований production contour (контур продуктивного середовища);
- право аудиту;
- можливість пред'явити регресну вимогу;
- передбачувану модель підтримки.

2. Ownership and control (власність і контроль)

У договорі має бути прямо зафіксовано:

- кому належить source code (вихідний код);
- кому належать architecture artifacts (архітектурні артефакти), схеми, документація, інфраструктурні конфігурації;
- кому належить database schema (схема БД);
- кому належать deployment scripts (скрипти розгортання);
- кому належать generated templates (згенеровані шаблони документів);
- кому належить customer data (дані замовника / пацієнтів);
- хто контролює production accounts (акаунти продуктивного середовища);

- хто контролює encryption keys (ключі шифрування).

Що бажано для замовника

- production cloud account оформлений на замовника;
 - object storage, backups і logs оформлені на замовника;
 - домени, DNS, email sender configuration належать замовнику;
 - ключі шифрування або контролює замовник, або їхній доступ жорстко обмежений.
-

3. Controller / Processor model (модель контролера і процесора)

У договорі має бути чітко описано:

- хто є `controller` (контролером даних);
- хто є `processor` (процесором даних);
- чи є `sub-processors` (субпроцесори);
- чи потрібне окреме `DPA` (Data Processing Agreement, угода про обробку даних);
- який порядок погодження нових `subprocessors` (субпроцесорів).

Додаткові умови, які доцільно передбачити

- заборона залучати нових `subprocessors` (субпроцесорів) без письмового погодження;
 - обов'язок повідомляти про зміну `subprocessors` (субпроцесорів) завчасно;
 - право замовника заперечити проти нового `sub-processor`.
-

4. Security obligations (обов'язки щодо безпеки)

Договір повинен містити окремий security schedule (додаток по безпеці).

У ньому бажано зафіксувати:

- encryption at rest (шифрування в сховищі);
- encryption in transit (шифрування при передачі);
- access control model (модель доступу);
- MFA (багатофакторну автентифікацію) для адміністративного доступу;
- logging and monitoring (логування і моніторинг);
- backup and recovery (резервування і відновлення);
- vulnerability management (керування вразливостями);
- patch management (оновлення безпеки);
- secrets management (керування секретами);
- least privilege principle (принцип мінімально необхідних доступів).

Окремо потрібно погодити

- хто має доступ до production;
 - як видається тимчасовий доступ;
 - як логуються дії адміністраторів;
 - як часто перевіряються доступи;
 - хто відповідає за видалення доступів після зміни ролей або завершення проєкту.
-

5. Incident response (реагування на інциденти)

У договорі обов'язково потрібно прописати:

- що саме вважається security incident (інцидентом безпеки);
- що саме вважається personal data breach (інцидентом з персональними даними);
- у який строк постачальник повідомляє замовника;
- яким каналом відбувається повідомлення;
- хто координує incident response;
- які матеріали має надати постачальник після інциденту.

Мінімум, який варто вимагати

- immediate notification obligation (обов'язок негайного повідомлення);
 - initial incident report (первинний звіт про інцидент);
 - root cause analysis (аналіз кореневої причини);
 - remediation plan (план усунення наслідків);
 - post-incident report (підсумковий звіт).
-

6. Audit rights (права аудиту)

У договорі бажано мати:

- право замовника запитувати докази виконання security controls;
- право на periodic compliance review (періодичну перевірку відповідності);
- право перевіряти документацію subprocessors (субпроцесорів);
- право отримувати актуальний список осіб із доступом до production;
- право вимагати підтвердження backup tests, restore tests, patching records.

Якщо повний аудит неможливий

У такому випадку доцільно вимагати щонайменше:

- compliance evidence package (пакет доказів відповідності);
- security reports;

- incident summaries;
 - penetration testing summary;
 - insurance confirmation.
-

7. Liability and indemnities (відповідальність і відшкодування)

Це один із найважливіших розділів договору.

Потрібно чітко узгодити:

- liability caps (ліміти відповідальності);
- чи поширюються ці ліміти на data breach;
- чи є carve-outs (винятки з обмеження відповідальності);
- чи є indemnities (відшкодування збитків);
- чи покриваються regulator claims, third-party claims, forensic costs, notification costs.

Для замовника особливо важливо

- не допустити, щоб весь data-breach risk був перекладений на замовника;
 - передбачити окремий режим відповідальності за:
 - грубу недбалість;
 - невиконання security obligations;
 - unauthorized access;
 - subcontracting without approval;
 - невчасне повідомлення про інцидент.
-

8. Insurance (страхове покриття)

У договорі варто перевірити:

- чи має постачальник professional liability insurance (страхування професійної відповідальності);
 - чи має cyber liability insurance (кіберстрахування);
 - які ліміти покриття;
 - які виключення в полісі;
 - чи покриває поліс витрати даних, forensic response, notification costs, claims defense.
-

9. Service levels and operations (рівень сервісу та операційна модель)

Потрібно зафіксувати:

- support hours (години підтримки);
 - severity levels (рівні критичності інцидентів);
 - response times (строки реакції);
 - resolution targets (цільові строки вирішення);
 - maintenance windows (вікна обслуговування);
 - update policy (політику оновлень);
 - rollback procedure (процедуру відкату);
 - business continuity expectations (очікування по безперервності роботи).
-

10. Backup, recovery, and exit (резервування, відновлення і вихід)

У договорі обов'язково треба погодити:

- backup frequency (частоту резервування);
- retention of backups (строки зберігання резервних копій);
- recovery objectives (цілі відновлення);
- restore testing (тестування відновлення);
- disaster recovery obligations (обов'язки щодо аварійного відновлення).

Exit provisions (умови виходу)

Також потрібно передбачити:

- як замовник отримує повний export (експорт) даних;
 - як передається код і документація;
 - як видаляються копії даних після завершення співпраці;
 - як передаються доступи і ключі;
 - як довго постачальник зобов'язаний допомагати з transition support (перехідною підтримкою).
-

11. IP and reuse (інтелектуальна власність і повторне використання)

Потрібно окремо зафіксувати:

- що є work made for hire / custom deliverable (індивідуальним результатом робіт);
- що є pre-existing IP (раніше створеною інтелектуальною власністю постачальника);
- що саме замовник отримує:
- ownership (власність);
- perpetual license (безстрокову ліцензію);
- exclusive or non-exclusive rights (виключні чи невиключні права).

Без цього часто виникають спори щодо:

- reusable components (повторно використовуваних компонентів);
 - devops scripts;
 - templates;
 - libraries;
 - admin tooling.
-

12. Мінімальний список пунктів, які бажано бачити в договорі

- MSA / Master Services Agreement (рамковий договір)
 - SOW / Statement of Work (опис обсягу робіт)
 - DPA / Data Processing Agreement
 - Security Schedule (додаток по безпеці)
 - Sub-processor Schedule (перелік субпроцесорів)
 - SLA / Service Level Agreement
 - Incident Response Appendix
 - Backup & Recovery Appendix
 - Exit / Transition Appendix
 - Liability & Indemnity section
 - Insurance section
 - Audit Rights section
 - IP Ownership / License section
-

13. Висновок

Власна платформа дає перевагу не автоматично, а тільки якщо:

- правильно побудована архітектура;
- production control не розмитий;
- договори фіксують security obligations;
- є зрілий incident model (процес реагування на інциденти);
- є audit rights;
- є чіткий exit plan;
- є реальний механізм регресу до постачальника.

Тому для замовника питання має звучати не так:

"Чи безпечна власна платформа сама по собі?"

А так:

"Чи побудовані архітектура, договір і операційна модель так, щоб ризик був максимально контрольованим і доказово розподіленим?"

Оновлено: Квітень 2026